

Pinecastle - Control Crosswalk and Testing

Controls	17
Tested Controls	6
Exceptions	3
High Findings	1
Pass Rate	50%
Assessment Date	2026-09-02

High Criticality			
Control Domain	Control Count	Why It Matters	Assessor Note
Identity	3	2 Access is central to SOC 2 and customer trust.	Contractor accounts are where MFA evidence broke.
Vulnerability	2	2 Known weaknesses must be governed through SLAs.	Scanning passed; remediation SLAs are the gap.
Detection	1	1 Logs need owners and alert routing.	No log source inventory yet.
Response / Recovery	4	0 Plans must be exercised and recovery tested.	Plan exists; the tabletop and restore test do not.
Vendor / Change	2	1 Third parties and change can create hidden risk.	DataFlow AI conditional approval is the open vendor item.
Training / Data / Cloud	3	1 Control coverage must match business scope.	Contractor training evidence is still split out.

Control ID	Control Name	Control Statement	Domain	Owner	Frequency	Evidence	NIST Mapping	CIS	ISO	SOC 2	Control Criticality
AC-01	Multifactor Authentication	All workforce users use MFA; privileged users use phishing-resistant MFA where supported.	Identity	VP of IT	Continuous	MFA policy export; enrollment report; exception log	NIST CSF PR.AA; NIST 800-53 IA-2	CIS 6	ISO 27002 5.16, 5.17	SOC 2 CC6	High
AC-02	Quarterly Access Review	Critical application owners review user access quarterly and document removals or approvals.	Identity	GRC Lead	Quarterly	Access review export; reviewer signoff; remediation evidence	NIST 800-53 AC-2, AC-6	CIS 5, 6	ISO 27002 5.18	SOC 2 CC6	High
AC-03	Terminated User Removal	Departing users are removed from SSO and critical SaaS applications within one business day.	Identity	People Ops	Per termination	HR termination ticket; SSO deactivation log	NIST 800-53 PS-4, AC-2	CIS 5	ISO 27002 5.18	SOC 2 CC6	Medium
VM-01	Vulnerability Scanning	Production systems are scanned at least monthly and findings are tracked.	Vulnerability	Security Engineer	Monthly	Scan report; ticket export	NIST 800-53 RA-5	CIS 7	ISO 27002 8.8	SOC 2 CC7	High
VM-02	Critical Vulnerability Remediation	Critical vulnerabilities are remediated or exception-approved within SLA.	Vulnerability	Security Engineer	Monthly	Aging report; exception approvals	NIST 800-53 SI-2	CIS 7	ISO 27002 8.8	SOC 2 CC7	High
LOG-01	Security Logging	Critical cloud, identity, and SaaS logs are enabled, retained, and monitored.	Detection	Security Operations	Continuous	Log source inventory; alert routing matrix	NIST 800-53 AU-6, SI-4	CIS 8	ISO 27002 8.15	SOC 2 CC7	High
IR-01	Incident Response Plan	Incident-response plan defines roles, escalation, communications, and evidence retention.	Response	CISO	Annual	IR plan; approval record	NIST 800-53 IR-4; NIST SP 800-61	CIS 17	ISO 27002 5.24	SOC 2 CC7	Medium
IR-02	Incident Tabletop Exercise	Pinecastle performs an annual tabletop exercise and tracks lessons learned.	Response	CISO	Annual	Exercise agenda; participant list; lessons learned	NIST 800-53 IR-3	CIS 17	ISO 27002 5.24	SOC 2 CC7	Medium
BC-01	Backup Monitoring	Critical backups are monitored and failures are remediated.	Recovery	Infrastructure	Daily	Backup job logs; failure tickets	NIST 800-53 CP-9	CIS 11	ISO 27002 8.13	SOC 2 A1	Medium
BC-02	Backup Restoration Test	Backup restoration is tested at least annually.	Recovery	Infrastructure	Annual	Restore test record; RTO/RPO results	NIST 800-53 CP-10	CIS 11	ISO 27002 8.13	SOC 2 A1	Medium
TPRM-01	Critical Vendor Review	Critical vendors are assessed before onboarding and annually thereafter.	Vendor Risk	GRC Lead	Annual	Vendor assessment; SOC report; findings register	NIST SP 800-161; NIST CSF GV.SC	CIS 15	ISO 27002 5.19	SOC 2 CC9	High
CHG-01	Production Change Approval	Production changes require review, approval, and emergency post-review.	Change	Engineering Manager	Per change	Pull request; approval; emergency review record	NIST 800-53 CM-3	CIS 4	ISO 27002 8.32	SOC 2 CC8	Medium
SEC-01	Security Awareness Training	Employees and contractors complete annual security awareness training.	Training	People Ops	Annual	Training completion report	NIST 800-53 AT-2	CIS 14	ISO 27002 6.3	SOC 2 CC2	Medium
DATA-01	Data Retention and Disposal	Customer data retention and deletion are documented and periodically reviewed.	Data Protection	Legal / Privacy	Annual	Retention matrix; deletion evidence	NIST 800-53 SI-12	CIS 3	ISO 27002 5.33	SOC 2 Confidentiality	Medium
CLD-01	Cloud Configuration Monitoring	Cloud configuration baselines are monitored and exceptions are reviewed.	Cloud Security	Cloud Engineering	Monthly	Configuration alerts; exception review	NIST 800-53 CM-2, AC-3	CIS 4	ISO 27017:2026	SOC 2 CC7	High

Control ID	Control Name	NIST CSF / 800-53	CIS v8.1	ISO 27001/27002	SOC 2 / AICPA TSC	Cloud / Supply Chain Note	Mapping Note
AC-01	Multifactor Authentication	NIST CSF PR.AA; NIST 800-53 IA-2	CIS 6	ISO 27002 5.16, 5.17	SOC 2 CC6	N/A	CSF and 800-53 name the authenticator; CIS 6 and SOC 2 CC6 care about coverage. Enrollment reports have to include contractors.
AC-02	Quarterly Access Review	NIST 800-53 AC-2, AC-6	CIS 5, 6	ISO 27002 5.18	SOC 2 CC6	N/A	ISO 5.18 expects review of rights changes too, not only a periodic certification.
AC-03	Terminated User Removal	NIST 800-53 PS-4, AC-2	CIS 5	ISO 27002 5.18	SOC 2 CC6	N/A	800-53 PS-4 sets the trigger (termination); the one-business-day target is Pinecastle's own.
VM-01	Vulnerability Scanning	NIST 800-53 RA-5	CIS 7	ISO 27002 8.8	SOC 2 CC7	N/A	One scan report satisfies all four frameworks if it shows authenticated coverage.
VM-02	Critical Vulnerability Remediation	NIST 800-53 SI-2	CIS 7	ISO 27002 8.8	SOC 2 CC7	N/A	SOC 2 auditors will ask for the exception approvals, not just the aging report.
LOG-01	Security Logging	NIST 800-53 AU-6, SI-4	CIS 8	ISO 27002 8.15	SOC 2 CC7	N/A	CIS 8 is specific about retention; SOC 2 CC7 only asks whether anomalies are evaluated.
IR-01	Incident Response Plan	NIST 800-53 IR-4; NIST SP 800-61	CIS 17	ISO 27002 5.24	SOC 2 CC7	N/A	NIST SP 800-61 Rev. 3 is organized around CSF 2.0 functions, so the plan maps to both directly.
IR-02	Incident Tabletop Exercise	NIST 800-53 IR-3	CIS 17	ISO 27002 5.24	SOC 2 CC7	N/A	Only 800-53 IR-3 explicitly requires testing; the other mappings are by inference.
BC-01	Backup Monitoring	NIST 800-53 CP-9	CIS 11	ISO 27002 8.13	SOC 2 A1	N/A	Maps to SOC 2 A1 only if Availability is in scope for the report.
BC-02	Backup Restoration Test	NIST 800-53 CP-10	CIS 11	ISO 27002 8.13	SOC 2 A1	N/A	Same A1 dependency as BC-01.
TPRM-01	Critical Vendor Review	NIST SP 800-161; NIST CSF GV.SC	CIS 15	ISO 27002 5.19	SOC 2 CC9	NIST 800-161 supply chain	800-161 expects tiering before review frequency is set; SOC 2 CC9 only expects that vendor risk is assessed.
CHG-01	Production Change Approval	NIST 800-53 CM-3	CIS 4	ISO 27002 8.32	SOC 2 CC8	N/A	CIS 4 is about configuration, so this mapping is partial; CM-3 and CC8 are the real anchors.
SEC-01	Security Awareness Training	NIST 800-53 AT-2	CIS 14	ISO 27002 6.3	SOC 2 CC2	N/A	SOC 2 CC2 covers communication broadly; AT-2 is the closer fit.
DATA-01	Data Retention and Disposal	NIST 800-53 SI-12	CIS 3	ISO 27002 5.33	SOC 2 Confidentiality	N/A	Only maps to SOC 2 if the Confidentiality category is in scope.
CLD-01	Cloud Configuration Monitoring	NIST 800-53 CM-2, AC-3	CIS 4	ISO 27017:2026	SOC 2 CC7	ISO 27017 cloud-specific	ISO 27017 adds cloud-customer duties the other frameworks do not separate out.

Control ID	Control	Test Procedure	Evidence Reviewed	Sample Size	Pass Count	Conclusion	Exception	Severity	Remediation
AC-01	MFA Enforcement	Inspect IdP policy and sample 25 users including all privileged users.	MFA policy export; user enrollment report	25	23	Exception	Two contractor accounts lacked MFA evidence.	High	Require MFA before contractor access is restored.
AC-02	Quarterly Access Review	Inspect Q2 access review for Salesforce and GitHub.	Access review export; reviewer signoff	2	1	Exception	One review lacked approval timestamp.	Medium	Require dated approval and retained evidence.
VM-01	Vulnerability Scanning	Inspect monthly scan evidence for last three months.	Scan reports; ticket export	3	3	Pass	Scans completed; aging report can be improved.	Low	Add aging summary to monthly report.
IR-02	Incident Tabletop	Inspect annual tabletop evidence.	IR plan; exercise evidence	1	0	Exception	No current-year tabletop evidence.	Medium	Schedule tabletop and track lessons learned.
TPRM-01	Critical Vendor Review	Inspect critical vendor assessment evidence for DataFlow AI.	Assessment workbook; findings tracker	1	1	Pass	Conditional approval documented with open findings.	Low	Continue tracking vendor remediation.

Finding ID	Control ID	Finding	Severity	Root Cause	Risk	Remediation	Owner
CF-001	AC-01	Two contractor accounts lacked MFA evidence	High	Contractor onboarding not included in MFA evidence review	Unauthorized access risk and audit exception	Require MFA for contractors and update onboarding checklist	VP of IT
CF-002	AC-02	Q2 access review missing approval timestamp	Medium	Evidence retention process incomplete	Review cannot be fully evidenced	Require dated approval workflow	GRC Lead
CF-003	IR-02	No current-year tabletop evidence	Medium	Exercise not scheduled before readiness review	IR readiness not proven	Schedule tabletop and track lessons learned	CISO

Control ID	Evidence Request	Owner	Frequency	Acceptable Evidence	Evidence Note
AC-01	MFA policy export; enrollment report; exception log	VP of IT	Continuous	MFA policy export; enrollment report; exception log	Export must list every account, including contractors and service accounts.
AC-02	Access review export; reviewer signoff; remediation evidence	GRC Lead	Quarterly	Access review export; reviewer signoff; remediation evidence	Reviewer sign-off needs a date; an undated approval failed testing (CF-002).
AC-03	HR termination ticket; SSO deactivation log	People Ops	Per termination	HR termination ticket; SSO deactivation log	Pair each HR ticket with the matching deactivation timestamp.
VM-01	Scan report; ticket export	Security Engineer	Monthly	Scan report; ticket export	Include the scan scope so coverage can be checked against the asset list.
VM-02	Aging report; exception approvals	Security Engineer	Monthly	Aging report; exception approvals	Overdue items without an approval are exceptions, even if fixed later.
LOG-01	Log source inventory; alert routing matrix	Security Operations	Continuous	Log source inventory; alert routing matrix	No source inventory exists yet; this request is open.
IR-01	IR plan; approval record	CISO	Annual	IR plan; approval record	Approval record must postdate the last material change to the plan.
IR-02	Exercise agenda; participant list; lessons learned	CISO	Annual	Exercise agenda; participant list; lessons learned	Agenda alone is not enough; lessons learned must be tracked to closure.
BC-01	Backup job logs; failure tickets	Infrastructure	Daily	Backup job logs; failure tickets	Failure tickets matter more than success logs.
BC-02	Restore test record; RTO/RPO results	Infrastructure	Annual	Restore test record; RTO/RPO results	Record actual restore time against the stated RTO.
TPRM-01	Vendor assessment; SOC report; findings register	GRC Lead	Annual	Vendor assessment; SOC report; findings register	Use the DataFlow AI workbook as the sample.
CHG-01	Pull request; approval; emergency review record	Engineering Manager	Per change	Pull request; approval; emergency review record	Sample must include any emergency changes in the period.
SEC-01	Training completion report	People Ops	Annual	Training completion report	Contractor completion is reported separately today.
DATA-01	Retention matrix; deletion evidence	Legal / Privacy	Annual	Retention matrix; deletion evidence	Deletion evidence should come from the system, not a ticket saying it was done.
CLD-01	Configuration alerts; exception review	Cloud Engineering	Monthly	Configuration alerts; exception review	Exception reviews need a reviewer name and date.

Reference	URL	Use
NIST CSF 2.0	https://www.nist.gov/cyberframework	Program outcomes and governance alignment
NIST SP 800-53 Rev. 5 Release 5.2.0	https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls	Control catalog reference
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final	Control assessment and test procedure reference
CIS Controls v8.1	https://www.cisecurity.org/controls/v8-1	Practical safeguard mapping
ISO/IEC 27001:2022/Amd 1:2024	https://www.iso.org/standard/88435.html	ISMS requirements
ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	Security control guidance
ISO/IEC 27017:2026	https://www.iso.org/standard/43757.html	Cloud-service control guidance
AICPA Trust Services Criteria with revised points of focus 2022	https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022	SOC 2 readiness criteria
NIST SP 800-61 Rev. 3	https://csrc.nist.gov/pubs/sp/800/61/r3/final	Incident-response control guidance
NIST SP 800-161 Rev. 1 Update 1	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Supply-chain controls
Scenario dates and rating definitions	Fictional assessment assumptions; see shared company profile	../00-company-profile/Pinecastle-Company-and-GRC-Scope.md